

BÁO CÁO CHUYÊN ĐỀ

Kiến trúc SEC đã thực thi trên EGAL / Gia Phả Số

Security Doctrine v1.1 · Chỉ dẫn cho đội Hệ thống & Lập trình

Phiên bản tài liệu: 1.0.0

Ngày: 2026-07-28

Phạm vi code: Backend Wave 0–5 (Master Implementation Plan v1.2)

SSOT: EGAL-SEC Security Doctrine v1.1 · CED v1.1 · OPD v1.2 · Master Plan v1.2

Repo: github.com/QuangAGS/cmcodes · Docs: github.com/QuangAGS/CM-Docs

1. Mục đích & đối tượng đọc

Tài liệu mô tả kiến trúc an ninh (SEC) đã được hiện thực trên backend EGAL — không chỉ liệt kê file, mà giải thích vì sao từng lớp tồn tại, thứ tự bắt buộc trên pipeline, hợp đồng lỗi, và quy tắc khi mở rộng feature mới.

- Đội hệ thống / DevOps: hiểu boundary, worker, env cấm production, điểm quan sát (correlationId, BPL).
- Đội lập trình: biết gắn middleware đúng chỗ, không phá Q1, không bypass gate, cách ném lỗi CED.
- Reviewer / kiến trúc sư: đối chiếu SEC Doctrine v1.1 với code đã merge W0–W5.

2. Nguyên tắc cốt lõi SEC đã khóa trong code

2.1 Defense-in-Depth (nhiều lớp, mỗi lớp một trách nhiệm)

Không dựa một “firewall ảo” duy nhất. Mỗi request đi qua chuỗi lớp độc lập; lớp sau giả định lớp trước có thể bị qua (token giả, bot, tenant sai trạng thái).

2.2 Human-friendly security

Rate limit và message tiếng Việt hướng người cao tuổi; không siết single-user hợp lệ. Turnstile bắt buộc production nhưng tắt được bằng config có chủ đích (dev), không hardcode bypass trong source main.

2.3 Traceability (CED × SEC)

Mọi lỗi operational và log an ninh phải mang correlationId (header + body dual-contract khi qua global handler). Notification PENDING và BPL giữ correlation_id để nối HTTP → worker.

2.4 Least privilege + tenant isolation

CLAN_ADMIN chỉ trong tenant; SYSTEM_ADMIN bypass kiểm tra khóa tenant nhưng vẫn resolve context khi có slug/tenant_id. Role đúng nhưng status user/tenant chưa kích hoạt → chặn API quản trị (Heavy gate).

2.5 Fail closed trên cổng nhảy

Thiếu token, CAPTCHA fail, tenant TAM_NGUNG trên API duyệt, account lock → từ chối rõ mã; không “im lặng thành công”.

3. Sơ đồ pipeline request (HTTP)

Thứ tự chuẩn (không được đảo khi thêm route mới):

correlation → (optional slug/tenant resolve) → rateLimit → securityGuard? → verifyToken → checkRole → tenantStatus(Light|Heavy|whitelist) → handler → CED global handler

Lớp	Module / file	Trách nhiệm SEC
1. Correlation	correlation.middleware	Sinh/propagate X-Correlation-Id; gắn req.correlationId
2. Rate limit	rateLimit.middleware	login 10/1p, register 5/1p, onboarding write 20, admin 30, check-identity 20; key IP normalize localhost
3. SecurityGuard	securityGuard.middleware	restrictSuspiciousActivity trên query-reviewable, process-approval, onboarding admin
4. Turnstile	auth.controller + turnstile.utils	Gate TURNSTILE_REQUIRED; siteverify; honeypot hp_field → blockIP
5. IP block	ipBlock.middleware	Danh sách IP tạm khóa sau honeypot / suspicious

6. verifyToken	auth.middleware	JWT; dual req.user; INVALID_TOKEN/UNAUTHORIZED CED
7. checkRole	role.middleware	RBAC + user status DA_DUYET cho admin path
8. tenantStatus	tenantStatus.middleware	Light: BI_KHOA; Heavy: CHO_DUYET/TAM_NGUNG/BI_KHOA; SYS_ADMIN bypass check, giữ context
9. Handler	controller + service	Assert order login; business rules; insert notif PENDING in TX
10. Global CED	createGlobalErrorHandler({legacy:true})	Dual-contract JSON + log toLogPayload + correlationId

3.1 Ma trận gắn lớp theo nhóm route

Nhóm route	Lớp SEC tối thiểu
Public login/register/reset	correlation + rateLimit + Turnstile + honeypot + IP check (không verifyToken)
Auth /me	correlation + verifyToken
Admin approve / query-reviewable	rate (nếu có) + verifyToken + checkRole + requireActiveTenant(Heavy) + securityGuard
Onboarding user write	onboardingWriteRateLimiter + verifyToken
Onboarding admin review/approve	admin rate + verifyToken + checkRole + tenantStatusHeavy + securityGuard
POST /onboarding/clan/activate	write rate + verifyToken — WHITELIST không Heavy (TAM_NGUNG được kích hoạt)
Members list	verifyToken (+ role tùy route); filter status CHINH_THUC mặc định (SEC visibility)

4. Lớp xác thực & phiên (Authentication)

4.1 JWT verifyToken

- Path: src/middlewares/auth.middleware.js
- Thiếu token → UNAUTHORIZED; token sai/hết hạn → INVALID_TOKEN (403 operational).
- Gán dual fields trên req.user (userId/tenantId và biến thể legacy) để Q1 không gây FE/service cũ.
- Có thể bọc tenantContext.run() khi có tenant — không thay thế tenantStatus gate.

4.2 Login Assert Order (SEC × nghiệp vụ)

Thứ tự trong service/controller sau Turnstile (đã khóa W2):

- 1) Credential (sai → 401, log THAT_BAI, đếm attempt).
- 2) Lockout theo identifier (attempts / locked_until → 423 ACCOUNT_LOCKED).
- 3) User lifecycle (CHO_DUYET → 423 ACCOUNT_CHO_DUYET; TU_CHOI/BI_CAM... → 403 ACCOUNT_DISABLED).
- 4) Tenant lifecycle (cho phép CLAN_ADMIN login khi TAM_NGUNG để hoàn thiện; chặn chức năng duyệt bằng Heavy gate sau này).

Không đảo: không báo “tenant sai” trước khi biết password đúng (tránh user enumeration thô).

4.3 Turnstile & Honeypot

- securityConfig.TURNSTILE_REQUIRED (default true) + TURNSTILE_SECRET_KEY.
- validateTurnstile(token, ip, action) — action: login | register | forgot-password | verify-reset-code.
- Cấm TEMP { success: true } trên nhánh main; dev chỉ TURNSTILE_REQUIRED=false.
- hp_field có giá trị → blockIP + log HONEYPOT_DETECTED.

4.4 Rate limit & key IP

- express-rate-limit v7: validate:false (tránh ERR_ERL_* local); normalize ::1 → 127.0.0.1.
- 429: code LOGIN_RATE_LIMITED / ONBOARDING_RATE_LIMITED / ...; gán correlationId nếu có.

5. Phân quyền & cổng tenant (Authorization)

5.1 checkRole

- Path: role.middleware.js — rest params ...allowedRoles.
- Bắt buộc req.user; status user phải DA_DUYET trên path admin (chống CLAN_ADMIN còn CHO_DUYET leo thang).
- Sai role → 403 message rõ.

5.2 tenantStatus Light / Heavy

- Path: tenantStatus.middleware.js
- Light: chặn khi tenant BI_KHOA (và tương đương nặng).
- Heavy: chặn CHO_DUYET / TAM_NGUNG / BI_KHOA với mã TENANT_NOT_ACTIVATED | TENANT_PENDING_ACTIVATION | TENANT_DISABLED.
- requireActiveTenant = alias tenantStatusHeavy (Q1 tên cũ).
- SYSTEM_ADMIN: bỏ qua check status nhưng vẫn gán req.tenantGate / context nếu resolve được slug hoặc tenant_id.
- Lỗi qua next(createError(...)) — bắt buộc có correlationId trên response (W1 lock).

5.3 Whitelist kích hoạt dòng họ

POST /api/onboarding/clan/activate không gán Heavy: CLAN_ADMIN + tenant TAM_NGUNG được hoàn tất onboarding kích hoạt. Các API duyệt thành viên vẫn Heavy.

5.4 Visibility members (SEC L6 tinh thần)

- GET /members mặc định chỉ CHINH_THUC.
- Admin override: ?status=DU_BI | CHINH_THUC | ALL | includePending=true.
- Enum members chỉ DU_BI | CHINH_THUC — không dùng HOAT_DONG trên member.

6. Ủy quyền on_behalf_of (SEC D — W5)

- buildActorContext(req, { onBehalfOf }): actor_id = user đang auth; on_behalf_of = subject.
- Cấm ghi đè req.user.userId bằng target (tránh privilege confusion).
- BPL metadata: action DELEGATED_ACTION + actor_type + actor_id + on_behalf_of + correlation_id.
- Job: actor_type JOB_RUNNER, actor_id = tên job (onboardingExpire | tempUnlock).

Trạng thái: helper + writeBpl đã có; wire đầy đủ vào mọi nhánh processApproval là residual khuyến nghị.

7. Nhật ký an ninh & BPL

7.1 auth_logs / attempt

- logAttempt SUCCESS/THAT_BAI; failure_reason có tiền tố TURNSTILE_*, HONEYPOT_*, LOGIN_REJECTED_*.
- user_attempt_number hỗ trợ đếm nhanh anti-bruteforce.

7.2 business_process_logs

- Cột: correlation_id, attempt_no (unique cặp), process_type enum, actor_type, actor_id, tenant_id, process_status, metadata jsonb.
- Action constants: DELEGATED_ACTION, ONBOARDING_EXPIRED, USER_TEMP_UNLOCKED.
- Expire job: process_type ONBOARDING_CASE_EXPIRE; Unlock: USER_UNLOCK.

7.3 audit_logs

- Có correlation_id; dùng cho thay đổi dữ liệu thành viên/địa chỉ (không thay BPL quy trình).

8. Thông báo PENDING như outbox-lite (SEC × OPD)

Critical path (approve/reject/expire...): INSERT notifications status=PENDING trong cùng transaction nghiệp vụ — không “gửi email trong TX HTTP”.

8.1 Worker claim (W4)

```
SELECT ... WHERE (PENDING OR (SENDING AND locked_at < now()-10m)) AND attempts < max FOR UPDATE SKIP LOCKED
```

- TX claim → SENDING + locked_at + attempts++.
- Gửi OK → SENT; fail & attempts < max → PENDING (retry); attempts ≥ 3 → FAILED + reason.
- Log luôn in correlation_id.
- Multi-instance: hai worker không nhận cùng id (đã smoke).

Production: schedule node src/jobs/runNotificationWorker.js — cấm NOTIF_WORKER_FORCE_FAIL.

9. Jobs bảo trì an ninh / lifecycle (W5)

9.1 onboardingExpire

- Whitelist: DRAFT, PROFILE_COMPLETED, FAMILY_TREE_DRAFT, NEEDS_REVISION.
- updated_at < now() - 30 days; LIMIT 100; SKIP LOCKED.
- Atomic: EXPIRED + notif PENDING (event ONBOARDING_CANCELLED tạm) + BPL ONBOARDING_EXPIRED.

9.2 tempUnlock

- locked_until < now(); skip BI_CAM; restore pre_lock_status.
- BPL USER_TEMP_UNLOCKED; batch LIMIT 100.

Không chạy job nặng trong process HTTP request.

10. Hợp đồng lỗi an ninh (CED × SEC codes)

Mọi lỗi operational đi createError / BusinessError → global handler dual-contract:

```
{ success:false, error:{ code, message, correlationId }, code, message [, legacyCode ] }
```

Code	HTTP	Khi nào
UNAUTHORIZED	401	Thiếu Bearer token
INVALID_TOKEN	403	JWT hết hạn / sai
ACCOUNT_LOCKED / ACCOUNT_CHO_DUYET	423	Lock attempt hoặc chờ duyệt
ACCOUNT_DISABLED	403	TU_CHOI / BI_CAM / ...
TENANT_NOT_ACTIVATED	403	Heavy gate TAM_NGUNG / chưa kích hoạt
TENANT_NOT_FOUND	404	Slug tenant không tồn tại
LOGIN_RATE_LIMITED / ...	429	Vượt rate window
TURNSTILE_REQUIRED / FAILED	403	Thiếu/sai CAPTCHA

Quy tắc lập trình: trong middleware/service ném lỗi qua next(err) hoặc throw AppError — không res.json ad-hoc trên path đã chuyển CED (trừ Q1 legacy message string vẫn được global bọc khi possible).

11. Checklist khi thêm API mới (bắt buộc)

- 1. Có correlation trên app (đã global) — handler không xóa header.
- 2. Public nhạy → rateLimit (+ Turnstile nếu form bot).
- 3. Cần đăng nhập → verifyToken.
- 4. Admin nghiệp vụ → checkRole + tenantStatusHeavy (trừ whitelist có văn bản).
- 5. Hành động thay mặt user khác → buildActorContext + BPL DELEGATED_ACTION.
- 6. Side-effect critical → notif PENDING trong cùng TX; không gửi SMTP inline.
- 7. Lỗi → createError/BusinessError với code trong shared/errors/codes.
- 8. Không commit TURNSTILE bypass; không UPDATE PENDING không SKIP LOCKED.
- 9. Job batch phải LIMIT; không full-table lock.
- 10. Smoke: ít nhất 401/403/429 và một happy path; kiểm correlationId trên lỗi.

12. Biên giới trách nhiệm FE / BE

Backend (SEC)	Frontend
Enforce token, role, tenant, rate, captcha	Hiển thị widget Turnstile; gửi token
INVALID_TOKEN / 423 business codes	Clear storage, redirect login, message tiếng Việt
Heavy gate TENANT_NOT_ACTIVATED	Điều hướng hoàn thiện hồ sơ / không spam approve API
Không tin UI ấn nút = an toàn	UI chỉ hỗ trợ UX; mọi rule phải server-side

13. Cấu hình & env an toàn

- TURNSTILE_REQUIRED=true (production); SECRET chỉ env/secret manager.

- JWT secret, DEBUG_SECRET_KEY — không log.
- Cấm production: NOTIF_WORKER_FORCE_FAIL, TEMP captcha success, debug unblock-all không key.
- securityConfig là single source cho threshold login lock, suspicious window, honeypot block minutes.

14. Lỗ hổng / residual còn mở (không che)

Mục	Ghi chú
Channel notif thật	Worker stub SENT — SMTP/Zalo chưa production
Cron host	Jobs chỉ CLI; cần systemd/scheduler
DELEGATED_ACTION wire	Helper sẵn; chưa đủ mọi admin path
branch_name Prisma	query-reviewable select sai field — vá service
Redis / Outbox table	Cố ý chưa làm — Postgres SKIP LOCKED đủ giai đoạn hiện tại

15. Kết luận

Kiến trúc SEC trên EGAL đã được hiện thực theo hướng Defense-in-Depth có thứ tự pipeline rõ, cổng tenant tách Light/Heavy, login assert order, Turnstile cấu hình hóa, rate/guard entry, ledger notif PENDING + worker khóa hàng đợi, và nền BPL cho audit ủy quyền/job.

Tài liệu này là chỉ dẫn thiết kế sống: mọi PR an ninh/feature mới phải đối chiếu mục 3 (pipeline), mục 11 (checklist) và không phá các lock Master v1.2 đã nêu.

Tham chiếu kèm: Handoff-W0 ... Handoff-W5; EGAL-SEC Doctrine v1.1; báo cáo thực hiện Master Plan v1.2.

— Hết báo cáo chuyên đề SEC —